

KubeSight — Re-audit after Production Hardening

Branch: production-hardening (HEAD eabf09f3, 19 commits on master 705b79c8; 184 files, +11,291 / -2,252) · **Date:** 2026-09-26 · **Compared with:** the 2026-09-25 audit of master at 650996c4.

Method: seven fix agents (A–G), one agent for the old test failures (H), and three read-only re-audit agents that checked every non- row of the original against the final code. After that: full test suites, a real-Postgres check of the new leader lock, a browser sweep of 32 screens in mock mode, and live API checks. Anything that needs a live cluster, VM, Jenkins, Bitbucket, Hermes or store API is still marked *runtime unverified*. Nothing has been merged to master.

Legend:  Implemented ·  Partial ·  Frontend only ·  Backend only ·  Infra/config only ·  Not implemented ·  Legacy / superseded · **green = changed on this branch**

0. Verification summary

2,445 / 0

backend tests passed / failed (full suite, SQLite); 1 skipped = Postgres-only test, run separately

227 / 227

frontend tests (vite) · vite build succeeds

18 / 18

leader-election tests against a real Postgres 16, including the real advisory-lock test

32 / 32

screens load in the browser sweep with no console errors, crashes or failed API calls

Check	Result
Backend suite before this work (master)	16–19 failing tests (varied by run under load). All fixed at the root cause; see §9.
Live API checks (mock stack, ports 5055/5174)	PASS: viewer gets 403 on API tokens · admin gets 200 · Zoho and Jira webhooks 403 with no secret · /api/ai/health 404 · logout revokes the JWT (200 → 401) · YAML apply with a wrong phrase gets 400 · CI runners respond. Hidden Secret values: not checked live (the mock cluster has no Secrets); covered by unit tests and the MCP test.
Browser sweep (Edge headless, admin)	Dashboard, Users/Roles, API tokens, Ticketing (Zoho/Jira), Service Catalog (source/intelligence/pipeline/merge checks/builds), Inventory + Helm, Blueprints, Alerts, Integrations, Clusters + overview, Cluster Management, Cluster Builder Sources, Upgrade, Resources/Secrets, Change Bundles, Settings/Security, Audit logs, Mobile apps: all clean.
Not verified	Full backend suite on Postgres (Docker not available; only the leader-lock tests ran on Postgres). Production-mode container run. Real cluster, Bitbucket, Hermes, Jenkins and store flows.

1. Top findings from the 2026-09-25 audit — status now

#	Finding	Before	Now	What changed
1	Live API token committed in connect-hermes-to-kubesight.sh			Out of scope: the owner is rotating and removing it. The token is still in the file (twice) and in git history.
2	A "green" CI build may have run nothing (mock runner seeded enabled)			The mock runner is never eligible in real mode, can't be enabled (409), and existing rows are switched off at boot. Fresh real-mode installs enable the Kubernetes runner.
3	Default users with known passwords always seeded			Out of scope: the owner is removing them. admin/admin123, operator/operator123 and viewer/viewer123 are still seeded with MFA off.
4	API-token routes check no permission; no scopes			All 3 routes require api_tokens:manage plus the first-login gate. Token scopes are deferred (tokens still carry the owner's RBAC).
5	Kubeconfigs stored as plaintext files			Stored Fernet-encrypted as cluster-N.yaml.enc. Each kubectl/helm call gets a short-lived 0600 plaintext copy (in /dev/shm when available), deleted when the call ends. Existing files are migrated at boot.
6	GET /api/alerts sends notifications			The GET is read-only (also GET /alert-policies and the MCP read tool). Repeats are sent by a scheduler sweep.
7	Hermes pipelines auto-saved over the default pipeline			A proposal stays pending until a person clicks Accept or Discard. Replacing a hand-edited pipeline needs explicit confirmation.
8	Approval gate only on apply_yaml; typed phrase frontend-only			The gate covers YAML, restart, scale, rollback, Helm (now queued as a change bundle) and Cluster Builder day-two (refused). A call with no user is refused. APPLY <namespace> is checked on the server.
9	Ticketing webhooks accept anything with no secret			All 6 inbound endpoints return 403 with no secret and 401 with a wrong one (constant-time compare). Settings has a Generate-secret UI.

10	Root Jenkinsfile applies 9 missing manifests	✗	✓	The root Jenkinsfile and the empty Pipeline jenkins file are deleted. bitbucket-pipelines.yml is the only self-CI.
----	--	---	---	--

New issues found and fixed during this work

Issue	Fix
Cluster- and namespace-level CPU/memory policies could never fire in real mode (data read in the wrong format)	Fixed in the alert evaluator (area F)
Telegram approvals from an @handle chat with no approver list: any subscriber could approve a deploy	Those presses are now refused (area B)
The hermes-agent role granted nothing that works, which pushed operators to give Hermes admin tokens	Role is now ticketing:view + new ticketing:agent (the 4 ticket write tools) (area B)
A Windows checkout gives bundled manifests CRLF line endings, so their SHA-256 check fails and a Windows-built image would refuse its own add-ons	.gitattributes: backend/api/data/** -text (area H)
Seeding restored default permissions an admin had removed from built-in roles, on every boot	New role_default_grants ledger: each default is granted once (area H)
Auto-upgrade was always on, though the docs say KUBESIGHT_AUTO_UPGRADE defaults to false	Now opt-in (area H)
node_modules cache prune could delete the archive it had just saved	The new archive is excluded from the prune (area H)
Test runs overwrote the developer's real backend/data/kubeconfigs/cluster-1.yaml	Tests use a temporary kubeconfig directory (area C)
A demo record was returned for unknown ids even when real App Services/Clients existed	Demo fallback applies only while the real table is empty (area H)
An image built from a developer checkout would contain backend/data/ (kubeconfigs, artifacts)	backend/.dockerignore excludes /data
get_current_user's g cache could keep accepting a revoked token across requests	Cache is scoped to one request (area A)

2. What changed, by area

Area	Commit	Changes
A · Auth & secrets	8b0c547f	Permission and onboarding gate on API tokens · TOTP secrets encrypted (column widened, migration) · dedicated KUBESIGHT_SECRET_KEY (old keys still decrypt; KUBESIGHT_PREVIOUS_SECRET_KEYS for rotation) · production detection via APP_ENV / KUBESIGHT_ENV / FLASK_ENV · refuses to start in production with dev/missing keys, AUTH_REQUIRED=false, or a missing/unreachable DB · token_version revocation (logout, reset, disable, admin lock, MFA reset) · temporary password not returned on SMTP failure unless ALLOW_TEMP_PASSWORD_REVEAL · new secrets:reveal: Secret values hidden in YAML (keys kept), reveals audited, placeholder YAML can't be applied · Werkzeug debugger off in production.
B · Webhooks & Hermes	48742a56	All 6 ticketing webhooks reject when no secret is set, with Generate-secret UI and "rejecting" banners · Bitbucket X-Hub-Signature HMAC verified for merge checks · /api/ai/* removed (confirmed unused; Hermes uses /api/mcp and KubeSight calls Hermes's own API) · ticketing:agent permission and least-privilege hermes-agent role · Telegram @handle approval refusal.
C · Cluster access	45ae72ba	Kubeconfig vault (encrypted at rest, per-call temp copies, breaker/cache keyed by cluster id) · cluster delete removes the file and credentials and writes an audit row · real workload counts and PV/PVC capacity in the overview ("—" when unknown) · Upgrade Center jobs persisted in upgrade_jobs with heartbeat and interrupted-job recovery · SSH host-key routes and a Sources-tab panel (scan, pin, replace, delete; audited).
D · Native CI	7415cd9c	Mock runner blocked in real mode · runner chosen from all stages' requirements (capabilities U labels) · CI Assist Accept/Discard gate with replaceExisting guard · publish_artifact/scan can't be saved and parallelGroup is dropped (honest; not implemented) · purge NameError fixed · credential read-only/write toggle plus edit/delete UI · stale-build reaper based on last progress, with an overall deadline (sum of stage timeouts, 24 h hard cap) · KUBESIGHT-BUILD commit status for normal builds.
E · Deploy governance	923de2da	Helm install/upgrade/rollback/uninstall queued via change bundles (rendered preview, diff, executor) · registry image check on Helm · gate refuses calls with no user and no approval context · Cluster Builder day-two gated · APPLY <ns> checked on the server (YAML/image/wizard; UI fields added) · ticket validator on MCP/agent automation_run_start (new confidence arg) · edit_resource bundle action · single "Add Application" entry · StatefulSet headless Service and ingressClassName · automation success/failure emails · Blueprint "Deploy" renamed "Register instance".
F · Alerts & monitoring	98b79f73	Read-only alert APIs with scheduler-side delivery · real disk/PVC usage from the kubelet Summary API with a no_data state · log alerts auto-resolve after a quiet period · receiver severity/namespace/cluster filters enforced and editable · no fabricated dashboard data ("Collecting samples...", "No network metrics source").
G · Runtime & self-CI	be185589, 3f694687	Postgres advisory-lock leader election (scheduler tick on the leader only, a guarded CI pass, boot migrations under a startup lock, Cluster Builder heartbeat) · GUNICORN_WORKERS / THREADS configurable (default 1, see §8) · endpoint defaults APP_ENV=production, FLASK_DEBUG=false · Dockerfile HEALTHCHECK · nginx security headers, gzip and caching · Bitbucket Pipelines: tests on every PR, on main/master, and before tag image builds · production env docs with a secretKeyRef example.
H · Old test failures	8e0ce9bf, c6c16f39	All pre-existing failures fixed at the root cause (see §9 and the new-issues table above).

3. Feature map — status before and now

Every row of the original audit is listed. Evidence refers to the `production-hardening` branch.

3.1 Platform / Core

Feature	Before	Now	Evidence / note
Password login (username or email)	✓	✓	Unchanged
JWT sessions with purpose claim	✓	✓	Adds <code>ver</code> claim (<code>token_version</code>); key required in production
TOTP MFA	✓ plaintext secret	✓	Secret encrypted at rest; migration encrypts existing rows (<code>auth_service.py</code> , <code>migrate_rbac.py</code>)
First-login onboarding	✓	✓	Unchanged
Lockout	✓	✓	An admin lock now also revokes sessions; failed-attempt auto-locks don't (by design)
Security emails	✓ temp pwd returned on SMTP failure	✓	Not returned in production unless <code>ALLOW_TEMP_PASSWORD_REVEAL=true</code> ; UI shows "fix SMTP, then Resend"; SMTP errors audited
Logout	●	✓	Server-side revocation via <code>token_version</code> (signs the user out everywhere)
Users CRUD + admin recovery	✓	✓	Destructive admin actions now revoke sessions
Roles & permissions	✓	✓	New <code>secrets:reveal</code> , <code>ticketing:agent</code> ; removed defaults stay removed (<code>role_default_grants</code>)
Fine-grained access rules	✓	✓	Unchanged
Legacy cluster/namespace grants	⚠	⚠	Unchanged
Effective access summary	✓	✓	Unchanged
API tokens	●	●	Permission + onboarding gate fixed; per-token scopes still deferred
Audit log + CSV export	✓	✓	New events: secret reveals, host-key actions, cluster removal, SMTP failures
Workspace settings	✓	✓	Unchanged
Settings → Security card	●	●	Still display only (no self-service password/MFA change)
Secret encryption at rest (Fernet)	✓ dev-key fallback	✓	Dedicated key required in production; old keys decrypt only
DB bootstrap + migrations	✓ silent SQLite fallback	✓	Production refuses to start without a reachable <code>DATABASE_URL</code> ; dev fallback logs an <code>ERROR</code> ; boot migrations under a startup lock
Alembic	⚠	⚠	Unchanged
Mock vs real Kubernetes	✓	✓	Demo data fallback now gated by <code>DEMO_DATA_FALLBACK</code> and only fills in while the real table is empty
<code>AUTH_REQUIRED=false</code> kill switch	●	● dev-only	Refused in production (boot fails)
<code>KUBESIGHT_ENV</code> production mode	✗	✓	<code>runtime_config.py</code> : <code>KUBESIGHT_ENV / APP_ENV / FLASK_ENV = production</code> ; <code>enforce_production_config()</code>
TTL cache + cache warmer	✓	✓	Per process (see §8 on workers)
Hash routing, coach-mark tours	✓	✓	Unchanged
Containers / runtime	● 1 worker pinned	● improved	Leader election; <code>GUNICORN_WORKERS</code> configurable (default 1); <code>HEALTHCHECK</code> ; production defaults; <code>/data</code> excluded from the image

docker-compose			Postgres only (unchanged)
----------------	--	--	---------------------------

3.2 Kubernetes cluster management

Feature	Before	Now	Evidence / note
Auto-discover contexts · register by kubeconfig · manual register · update/test · multi-cluster list · topology map · problem pods · events · exec · pods	✓	✓	Unchanged; all kubectl calls now go through the kubeconfig vault
In-cluster service account			Docs now list the <code>nodes/proxy get</code> RBAC needed for disk/PVC alerts
Delete cluster		✓	Deletes the kubeconfig file, clears credentials and status, writes a <code>cluster_removed</code> audit row (row kept soft-deleted for history)
Cluster health			Still healthy/warning only
Cluster overview	zeros	✓	Real Deployment/StatefulSet/DaemonSet counts, PV capacity and PVC claimed; unknown values show "—"
Namespaces · StatefulSets/DaemonSets · ReplicaSets/Jobs/CronJobs · Services · StorageClass			Unchanged
Deployments	✓	✓	Edit and restart go through the approval gate (queued)
Ingress / ConfigMaps / Secrets	✓ secret data exposed	✓	Secret values hidden without <code>secrets:reveal</code> (REST + MCP); only the redacted form is cached
PVC/PV browsing · Resource delete	✗	✗	Unchanged (overview shows capacity totals only)
Nodes (roles, no cordon/drain)			Unchanged
K8s upgrades (Upgrade Center)	jobs in memory		Jobs persisted with heartbeat and interrupted recovery; auto-upgrade opt-in (<code>KUBESIGHT_AUTO_UPGRADE</code>). Managed clouds still precheck-only

3.3 Cluster Builder

Feature	Before	Now	Evidence / note
Wizard/CRUD · preflight · stacked HA · Calico/Flannel · metrics-server/NGINX/MetalLB · build profiles · onboard/kubeconfig · copy workloads · NFS storage plan	✓	✓	Unchanged; bundled manifests pinned to LF so their digests match on every OS
Phase machine / resume / retry	✓ single-process	✓	Heartbeat plus leader election prevent a second process relaunching a live build. Real-VM validation still pending
Managed HAProxy + Keepalived + VIP · OS adapters (RHEL)	✓ uncertain	✓ uncertain	Runtime unverified on real VMs
External LB / manual endpoint	✓ validation only	✓ validation only	Unchanged
Cilium			Flag only, no bundle
NFS provisioner / StorageClass add-on	✗	✗	Unchanged
Day two: add workers	✓ CSR gap	✓	CSR approver re-rendered (fixed on master in 3df876cb). New: day-two actions refused on approval-gated clusters without a live approval
Remove node, add CP/LB, teardown, IPAM, kube-vip	✗	✗	Unchanged
vSphere connections · SSH credentials/profiles	✓ (edit)	✓ (edit)	Unchanged
SSH host-key policies strict/TOFU/pinned		✓	Routes (list/scan/pin/delete, <code>ssh_credentials:manage</code>) and Sources-tab HostKeysPanel; audited

3.4 Monitoring / observability

Feature	Before	Now	Evidence / note
Pod & node CPU/memory · dashboard summary · logs snapshot/SSE · noise filter/search/download	✓	✓	Unchanged; log streams hold their kubeconfig copy only while open

Prometheus/Grafana/Loki · aggregated logs	✗	✗	Unchanged (deferred)
Disk metrics	✗	●	Kubelet Summary API (<code>k8s_volume_stats.py</code>), used by alert rules; not on the dashboard yet
Network metrics	● fake	✗ honest	Fake random walk removed; panel says "No network metrics source"
Historical metrics	● random seed	●	Buffer starts empty and fills from real polls only; still not stored server-side
Legacy <code>GET /api/logs</code>	🗑	🗑	Unchanged

3.5 Alerts

Feature	Before	Now	Evidence / note
Built-in CPU alerts · policy CRUD · metric rules · service/automation alerts · SMTP/Slack/webhook · receivers/groups/delivery log · metric auto-resolve	✓	✓	Cluster/namespace CPU & memory policies now fire in real mode (bug fixed)
Scheduler (15 s tick)	✓	✓	Runs on the elected leader; standby takes over within one tick; also sends repeat notifications
PVC % / disk % rules	● misleading	✓	Real usage; <code>no_data</code> state instead of invented numbers; needs <code>nodes/proxy</code> RBAC
Log-pattern alerts	✓ never resolve	✓	Auto-resolve after a quiet period (<code>resolveAfterSeconds</code> , editable)
Receiver severity/namespace/cluster filters	● dead	✓	Enforced on every dispatch path; editable in the receiver form
Telegram/WhatsApp/Teams/PagerDuty alerts · resolved notifications · ack/silence	✗	✗	Unchanged (deferred)
Settings-based routing	🗑	🗑	Unchanged

3.6 Application / service management

Feature	Before	Now	Evidence / note
App Services · topology/DR · components · clients · connectivity · Blueprints CRUD	✓	✓	Unchanged; demo fallback no longer returns fake records for unknown ids
Egress connections	🗑	🗑	Unchanged
Deploy from Blueprint	● record-only	● honest	Renamed "Register instance" (<code>/register</code> alias, <code>appliedToCluster:false</code>); still creates no K8s objects (by decision)
Blueprint instances <code>/api/app-services</code>	●	●	Still no UI
Inventory app catalog list · ApplicationDetailsPage	●	●	<code>InventoryHubTable</code> still orphaned; details page still deep-link only

3.7 Deployment

Feature	Before	Now	Evidence / note
Wizard from scratch · kinds · env/probes/volumes · namespace select · user templates · schema deploy · raw YAML · Helm catalog · chart templates · Excel forms · deployment requests · change bundles	✓	✓	YAML/image/wizard applies check <code>APPLY <ns></code> on the server
Manual PV for non-admins	●	●	Unchanged
Tolerations, affinity, initContainers, securityContext, serviceAccountName, hostAliases	✗	✗	Unchanged (deferred)
StatefulSet headless Service	●	✓	<code>{app}-headless</code> Service (<code>clusterIP: None</code>) emitted
Ingress class	●	✓	Optional <code>ingressClassName</code> (empty = cluster default); field in the wizard

Deploy from Docker image (AddAppModal)	● gated backwards	✓	One "Add Application" entry; options shown per permission
Deploy from source	✗	✗	Only via ticket automation
Registry connections + image check	✓ not Helm	✓	Also runs on Helm (rendered manifest), honouring off/warn/block
Deployment approval gate	● apply_yaml only	✓	YAML, restart, scale, rollback, edit, Helm (queued), day-two (refused); a no-user call is refused
Restart / scale / rollback	✓ Deployments only	✓ same	Restart covers pod/deploy/sts/ds; scale and rollback still Deployment-only
Rollout watch + auto-undo · deployment versions	✓ scoped	✓ same	Unchanged scope
Helm releases / install / rollback / uninstall	✓	✓	Queued for approval on gated clusters and executed on approval; the preview shows the rendered manifest with Secrets redacted
Helm upgrade, repos, chart search	●	●	Still no UI
Excel forms → bundle/approval	●	●	Unchanged
Bundle action <code>edit_resource</code>	● broken	✓	Accepted and executed

3.8 CI/CD (native KubeSight CI)

Feature	Before	Now	Evidence / note
Register service · test source/branches · app types · manual editor · templates · default pipeline · checkout/command/container_image · when/params/variables · secrets & masking · host aliases · engine/queue · agent · workspace browser · BuildKit · Nexus push · Trivy gate · caches · resources · stage matrix · Jenkinsfile import	✓	✓	Unchanged (the node_modules cache prune bug is fixed)
Repository URL / GitLab / GitHub	✓ Bitbucket only / ✗	same	Unchanged
Repository credentials	● forced read-only	✓	Read-only/write selector, edit, delete (409 when in use)
Framework / build-system profile	●	●	Unchanged
Generated pipeline review / accept	● bypassed	✓	Accept / Discard gate; <code>replaceExisting</code> for hand-edited pipelines
Stage types <code>publish_artifact</code> / <code>scan</code>	✗ skipped	✗ retired	Can't be saved any more; stored ones still skip with a reason
Parallel stages	✗	✗ honest	<code>parallelGroup</code> no longer accepted or emitted
Runner matching	● first stage	● mostly	Union of all running stages' requirements, capabilities U labels, clear conflict errors; still one runner per build
Kubernetes runner	✓ off by default	✓	Enabled on fresh real-mode installs; mock runner never used in real mode
ssh_linux runner · per-stage PVC · S3/Nexus-raw artifacts · push/tag triggers	✗	✗	Deferred
Artifacts purge	✓ NameError	✓	Fixed
History / timeouts	✓ 60-min reaper	✓	Idle timer from last progress plus an overall deadline
Bitbucket PR merge checks	✓ HMAC caveat	✓	Real X-Hub-Signature HMAC verified (runtime unverified)
Build status for normal builds	✗	✓	<code>KUBESIGHT-BUILD</code> commit status (needs a write credential and a public URL)

Jenkins integration			Fallback still present
Root Jenkinsfile · Pipeline jenkins		removed	Deleted
bitbucket-pipelines.yml		improved	Tests on every PR, on main/master and before tag image builds

3.9 Hermes AI

Feature	Before	Now	Evidence / note
MCP server /api/mcp	93 tools	93 tools	66 read / 27 write · ci 28 · clusters 10 · workloads 8 · deploys 14 · observability 7 · apps 8 · platform 13 · tickets 5. Ticket writes need ticketing:agent; Helm tools can queue; Secret values hidden
Application Intelligence · build verified · findings · PR from patches · runtime intelligence · CI Assist			CI Assist now requires human Accept
Ticket agent (Telegram + UI approvals)	uncertain	uncertain	@handle approval refusal; MCP/agent starts validated
Legacy /api/ai/*	broken	removed	routes/ai.py deleted; no remaining callers
hermes-agent service account	label only		Now ticketing:view + ticketing:agent (MCP tools work); applications:execute is still checked nowhere
Model selection			Env vars, unchanged
In-app AI chat · production restriction · Hermes creating tickets			Deferred (production relies on per-cluster approvals, now incl. Helm)
Hermes infra (connect script)	leaks token	leaks token	Out of scope, owner action

Capability table changes: Cluster health: MCP only (/api/ai gone) · Helm upgrade/rollback/uninstall: gated (queued) · Pipeline creation: human accept · Ticket-driven deploy: validator enforced for agent/MCP starts (operator UI and webhook auto-runs intentionally not re-validated) · Tickets: separate ticketing:agent permission · Telegram approvals: stricter.

3.10 Ticketing & deploy automation

Feature	Before	Now	Evidence / note
Provider layer · Zoho client/sync · write-back · field/layout editor · queued runs/overrides			Unchanged
Jira Cloud/DC parity	uncertain	uncertain	Runtime unverified
Inbound tickets (webhook)	open w/o secret		Rejected when no secret is set (403) or the secret is wrong (401), incl. comment webhooks; Generate-secret UI
Zoho whole-layout writes			Still gated off (ZOHO_LAYOUT_WRITE_ENABLED)
Internal ticketing			Deferred
Deploy automation			Validator on MCP/agent starts (confidence arg)
Outcome emails	rollout failure only		Success and failure emails to admins, once per outcome
Legacy /api/zoho/*			Still present; its inbound paths use the same secret check

3.11 Mobile applications

No mobile code changed on this branch: every row keeps its original status (register/builds/download · CI ingest · Jenkins fetch · direct upload · local FS storage · signature gate · Jenkins-only re-sign · Google Play / App Store publish unverified · macOS CI signing). Local artifact directories are now kept out of the backend image.

3.12 Security scanning

Feature	Before	Now	Evidence / note
Trivy CI gate · App Intelligence scanners · merge-check tools · Dockerfile advice · NetworkPolicy for internal jobs			Unchanged
Direct NVD client · NetworkPolicy for user apps			Unchanged
Merge-check webhook authentication	–		HMAC-SHA256 or shared secret; rejects when no secret is stored

3.13 Integrations

Unchanged apart from: Bitbucket webhooks now HMAC-verified · Telegram approvals stricter · Jenkins kept only as the deploy-automation and mobile fallback (root Jenkinsfile deleted). Still **✗**: GitLab/GitHub, Harbor/Docker Hub-specific support, direct OpenAI/Anthropic SDK, WhatsApp, Prometheus.

4. End-to-end workflows — what changed

Workflow	Change on this branch
Register an existing cluster	The kubeconfig is written encrypted (<code>cluster-N.yaml.enc</code>); every kubectl/helm call decrypts to a short-lived copy. Delete removes the file.
Provision a cluster	Builds send a heartbeat; resume is safe across processes. Day-two actions on approval-gated clusters need a live approval.
Deploy an application	Server checks <code>APPLY <ns></code> ; the gate covers every change type; Helm is queued like YAML; the registry check also runs for Helm.
Run a CI build	Runner chosen for all stages together; the mock runner is never used in real mode; <code>KUBESIGHT-BUILD</code> status posted; reaper based on progress.
Register a CI service (Hermes mode)	The proposal is validated and waits for Accept ; no auto-save.
Merge check	Bitbucket's own "Secret" field now works (HMAC).
Hermes interaction	Mint the Hermes <code>ksa_</code> token as the <code>hermes-agent</code> user; <code>/api/ai</code> is gone.
Alert handling	Evaluation and delivery happen only in the leader's scheduler; receiver filters apply; log alerts resolve; <code>no_data</code> instead of fake values.
Ticket → deploy	Webhooks need the inbound secret; MCP/agent starts pass the validator; success and failure emails.

5. Hidden / disconnected features

Item	Before	Now
AddAppModal (image / YAML / Helm)	gated backwards	Fixed: single "Add Application" entry
TicketAgentConfigPanel	possibly no importer	Mounted (lazy import in integration panels)
ApplicationDetailsPage · InventoryHubTable · AlertRoutingModal, HealthRing, LiveLogViewer · dashboard widget registry · unused API wrappers	hidden / orphaned / dead	Unchanged
Legacy <code>/api/ai/*</code> · <code>/api/zoho/*</code>	no UI	<code>/api/ai</code> removed; <code>/api/zoho</code> kept (inbound paths secured)
Unused models / columns	dead	<code>parallel_group</code> no longer written or accepted (column kept); others unchanged
Feature flags	9 flags	New: <code>SCHEDULER_LEADER_ELECTION</code> , <code>DEMO_DATA_FALLBACK</code> , <code>CI_BUILD_STATUS_REPORTING</code> , <code>ALLOW_TEMP_PASSWORD_REVEAL</code> , <code>KUBESIGHT_AUTO_UPGRADE</code> (now honoured)

6. Duplicate / legacy systems

Domain	Now
CI: native vs Jenkins	Root <code>Jenkinsfile</code> and <code>Pipeline jenkins</code> deleted; the Jenkins fallback remains for deploy automation and mobile re-signing.
Self-CI	<code>bitbucket-pipelines.yml</code> only, with test gates.
AI access	MCP only (<code>/api/ai</code> removed).
Service catalog models · "App service" twins · manifest generators · <code>api.js</code> barrel · CSS layers · Alembic · legacy grants · settings routing	Unchanged (refactors, not blockers).

7. Database and API changes

Kind	Change
New tables	<code>role_default_grants</code> (grant ledger) · <code>upgrade_jobs</code> (persisted Upgrade Center jobs)
New/changed columns	<code>User.token_version</code> · <code>User.totp_secret</code> widened to 255 and encrypted · alert receiver filter columns ensured

Not in the DB	Kubeconfigs as encrypted files · leader election uses Postgres advisory locks (no table) · automation <code>origin</code> and outcome-mailed markers in the run's JSON
New endpoints	GET/POST/DELETE <code>/api/ssh-host-keys</code> , POST <code>/api/ssh-host-keys/scan</code> · POST <code>/api/ci/analyses/<id>/reject</code> · POST <code>/api/service-blueprints/<id>/register</code>
Changed endpoints	Helm install/upgrade/rollback/uninstall may return 202 queued · YAML/image/wizard apply return 400 on a wrong phrase · ticketing inbound returns 403/401 without a valid secret · API token routes need <code>api_tokens:manage</code> · GET <code>/api/alerts</code> read-only
Removed endpoints	<code>/api/ai/*</code>

8. Executive summary

Production readiness. All ten top findings are fixed except the two the owner is handling personally (the committed token and the default users) and token scopes, which were deferred. The backend suite goes from 16–19 failures to **0**. Nothing has been merged to master: the work is on `production-hardening` for review.

Go-live checklist (owner actions)

#	Action	Why
1	Rotate the <code>ksa_</code> token, remove <code>connect-hermes-to-kubesight.sh</code> from the repo, and mint Hermes's new token as the hermes-agent user	Finding #1; the role now works with least privilege
2	Remove or change the seeded default users (<code>admin/admin123</code> etc.)	Finding #3
3	Create a Kubernetes Secret with <code>KUBESIGHT_SECRET_KEY</code> (<code>openssl rand -hex 32</code> , kept stable) and a real <code>JWT_SECRET_KEY</code> ; set a reachable <code>DATABASE_URL</code>	The pod refuses to start in production without them. Changing the key makes kubeconfigs undecryptable
4	Set the Zoho and Jira inbound webhook secrets and add them to the senders before upgrading	Webhooks now return 403 until a secret is set
5	Grant the KubeSight service account <code>get</code> on <code>nodes/proxy</code>	Real disk/PVC alerts (otherwise "No data")
6	Delete the <code>cluster-monitor</code> job from <code>hermes/hermes/.hermes/cron/jobs.json</code>	It fails hourly; its only target, <code>/api/ai</code> , is gone
7	Check <code>backend/data/kubeconfigs/cluster-1.yaml</code> in the main checkout; re-upload if <code>custom-1</code> is a real cluster	Earlier test runs overwrote it with a test config
8	Re-check-out <code>backend/api/data</code> in existing Windows checkouts (<code>git checkout -- backend/api/data</code> after deleting <code>addons, cni</code>)	Line-ending fix for the bundled manifest digests
9	Run the backend suite once against Postgres (<code>TEST_DATABASE_URL=postgresql://... pytest</code>)	Only the leader-lock tests ran on Postgres here
10	Set <code>KUBESIGHT_AUTO_UPGRADE=true</code> only if KubeSight should run kubeadm/minikube upgrades itself; apply <code>k8s/ci-runner.yaml</code> for the now-enabled Kubernetes runner; set <code>PUBLIC_BASE_URL</code> for build statuses	Behaviour changes on this branch

Behaviour changes operators will notice

- Logout signs a user out in every browser; password reset, disable, admin lock and MFA reset do too.
- Secret values are hidden for anyone without `secrets:reveal` (admin and cluster_admin have it).
- YAML/image deploys and resource edits require typing `APPLY <namespace>`.
- Helm on approval-gated clusters is queued (202) instead of refused.
- Hermes CI proposals need an explicit Accept; `publish_artifact/scan` stages can't be saved.
- MCP `kubesight_automation_run_start` needs `confidence: "High"` or an approval.
- Repeat alert notifications come only from the scheduler; keep `ALERT_POLICY_SCHEDULER` on.

Still partial or open (not blockers, or accepted)

- **API token scopes:** tokens still carry the owner's full RBAC (deferred).
- **Default worker count 1:** more workers are now safe for background jobs, but TTL read caches are per process, so lists can lag a write by 10–30 s with more workers or replicas.
- `helm get values` / **release manifests** can contain Secret material and are gated only by `helm:values:view`.
- **Containers run as root;** `/health` is unauthenticated and reports user counts.
- `applications:execute` is checked nowhere; the operator UI and webhook auto-runs are not re-validated by the ticket validator (explicit human or picklist actions, by design).
- Runner selection is still one runner per build; cluster health is still binary; StatefulSet/DaemonSet/Job/Service screens are still view-focused.
- Runtime-unverified on real infrastructure: Cluster Builder on VMs, merge checks against Bitbucket, Jira, ticket agent, Play/App Store publishing, BuildKit/Trivy images.

Planned, not implemented (deferred features)

Prometheus and stored metric history · network metrics · PVC/PV browsing and resource delete · alert ack/silence and Telegram/WhatsApp alerts · parallel stages · `ssh_linux` runner · `publish/scan` executors · S3 artifacts · GitLab/GitHub · push/tag CI triggers · per-stage PVC workspaces · IPAM, kube-vip, node removal, teardown · NFS provisioner add-on · tolerations/affinity/securityContext/hostAliases for apps ·

9. Pre-existing test failures — root causes

Tests	Root cause	Fix
test_application_services ×3, test_clients ×2	Demo fallback in mock mode filled "empty" lists and answered unknown ids	Code: DEMO_DATA_FALLBACK flag (off in tests); by-id fallback only while the table is empty
test_cluster_builder_addons_proxy ×3, test_cluster_builder_k8s_versions ×2	CRLF checkout changed the bytes of SHA-pinned manifests	Repo: .gitattributes -text for backend/api/data/**
test_registry_credentials_require_operator_secret	Stale test (removed the JWT key after signing its token)	Test updated; error message names KUBESIGHT_SECRET_KEY
test_seed_preserves_custom_role_permissions	Seed re-granted removed defaults on every boot	Code: role_default_grants ledger
test_delete_role_with_users_blocked	Stale: role delete deliberately unassigns users since cf24b237	Test renamed and updated
test_kubeadm_without_auto_upgrade_returns_manual_plan	auto_upgrade_enabled() always returned True	Code: honours KUBESIGHT_AUTO_UPGRADE (default false)
test_ci_cache_node_modules (flaky)	60 s subprocess timeout under load; prune could delete a fresh archive	Test timeout raised; code prune excludes the new archive
test_yaml_apply_requires_confirmation	Server-side phrase check removed in bb8a2519	Fixed by area E (server check restored)
test_trigger_variables_reach_every_stage_environment	Assumed a starter template that service creation no longer uses	Test declares its parameter

Generated 2026-09-26 from the production-hardening branch. Source of truth: the code and test runs above; the original 2026-09-25 PDF is kept alongside for comparison.